脆弱性検知条件の供給源の再検討

――検知精度によるNVD・VulnCheck・一次データソースの比較とLLMによる構造化――

Norihiro Nakaoka, Shunichi Shinohara
@ CSS 2026 2F1-1

whoami

Norihiro Nakaoka / @MaineK00n



Future Corporation, Cyber Security Innovation Group
OSS Vulnerability Scanner: Vuls[1] Committer

[1] https://github.com/future-architect/vuls

論文・スライドを手元でみたい方へ



https://github.com/vulsio/css2026-data

NVDは, 脆弱性に検知条件を付けなくなった

検知条件	どの製品の, どのバージョンが影響を受けるか
付与率	2023年まで 100% → 2024年 80.5% → 2025年 62.6% → **2026年 56.1%**
Deferred	NVDが「解析しない」と明示した状態。減った分のほとんど
経過	Deferred の半分は, 公開から286日以上経っても付かない

対象: NVDの全件353,704件（2026/07/29時点, Rejectedを除く）

付与率で, 検知精度は分かるのか？

よくある想定

1. **VulnCheck で補完できる**

   2025年の付与率：NVD 62.6% → VulnCheck を加えて 76.1%

2. **付与率100%だった2023年以前のCVEなら, NVDで十分**

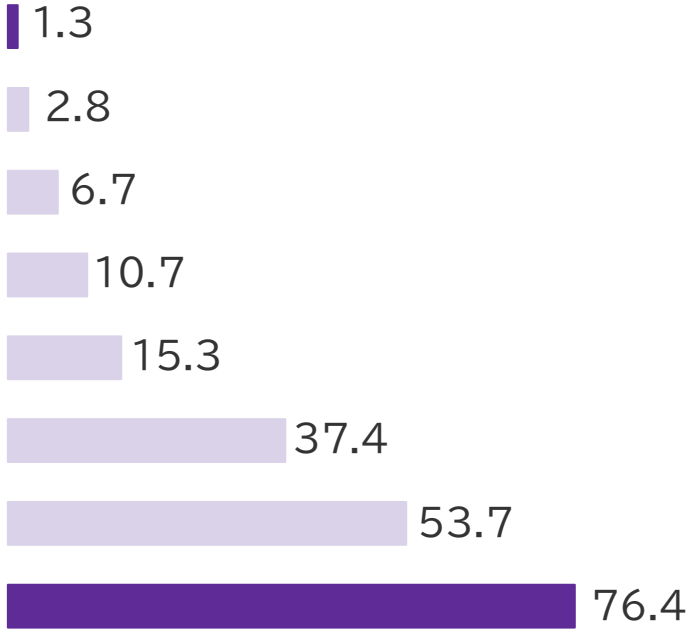
→どちらも, 付与率が高ければ大丈夫と見ている

データソースだけを変えて，同じ環境を検知する

基準DB	ベンダ情報のみ
比較DB	NVDのみ ／ VulnCheckのみ ／ NVD＋VulnCheck
検知対象	FortiOS・Cisco・Windows・macOS・OpenSSH の10環境
未検知	基準DBが検知し，比較DBが検知しない
過剰検知	比較DBが検知し，基準DBが検知しない

付与率は検知精度を予測しない

環境	採番元別のNVD付与率(%)	NVDのみ 未検知率(%)
Windows Server 2022	99.7	1.3
Windows 11 23H2	99.7	2.8
macOS 14.7.4	99.4	6.7
FortiOS 7.0.1	99.6	10.7
macOS 10.13.3	99.4	15.3
Cisco IOS XE 16.12.1	77.2	37.4
Cisco IOS 15.6(1) T1	77.2	53.7
FortiOS 5.2.0	99.6	76.4



採番元別のNVD付与率は2024年以降のCVEを対象｜NVDのみ　未検知率は全期間のCVEを対象

付いている≠合っている

測ったもの	Fortinetのアドバイザリ(2022年以降)を, NVDがどれだけ正確に写せているか(影響を受けるバージョンごと)
Fortinet製品（656 CVE）	NVD付与率 99.6%でも, 影響を受けるバージョンの記述が一致したのは **63.1%**
組み込み部品（54 CVE）	NVDもVulnCheckもFortinet 製品を **1件も載せていない** 例:regreSSHion(OpenSSH)—— Fortinetは FG-IR-24-258でFortiADC・FortiWebなどが影響と公表. NVDのCPEはopenbsd:opensshだけ

NVDの誤り方は, 製品ごとに違う

影響する製品が載らない

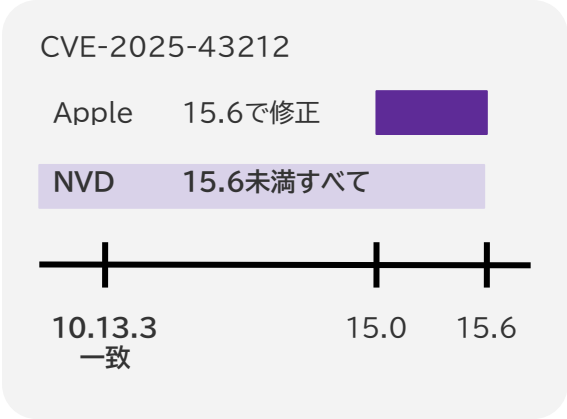
FortiOS 5.2.0



取りこぼす: 未検知 76.4%

範囲に下限がない

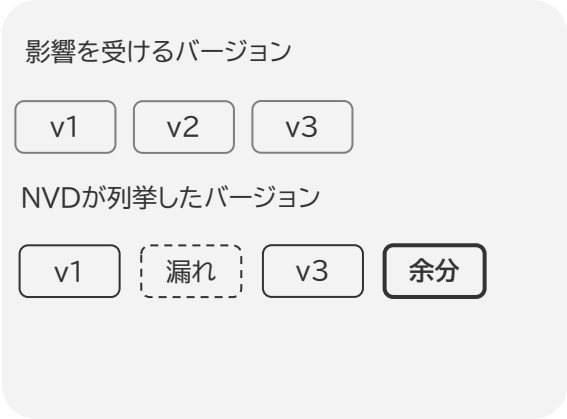
macOS 10.13.3



出しすぎる: 過剰検知 81.5%

バージョン列挙がずれる

Cisco IOS 15.6(1)T1



両方: 未検知 53.7%
過剰検知 23.2%

VulnCheckは, 製品によって救いにも害にもなる

	製品	NVD→NVD+VC	何が起きたか
救い	Microsoft Edge	未検知 96.2% → 0.5%	NVDが載せないMicrosoft Edgeを, VulnCheckが補った
害	Windows 11 23H2	過剰検知 0.6% → 70.6%	NVDが「Windows 全般」と書いた2007年の脆弱性を, VulnCheckがWindows 11 23H2にも当てはめた
変わらない	FortiOS 5.2.0	未検知 76.4% → 75.6%	組み込み部品の脆弱性は, VulnCheckでも載らない

2023年以前のCVEでも, NVDは誤る

製品	2023年以前の CVE で, NVD が取りこぼした割合
FortiOS 5.2.0	76.4%
Cisco IOS 15.6(1)T1	56.0%

→ 付与率100%の時代から, 誤りは付与率に現れない形であった

ベンダ情報は常に正解か？

OpenSSH 8.5p1	検知件数: 両方 6 / NVDのみ 18 / ベンダ情報のみ 1
NVDだけが検知した18件	すべて MITRE の採番, 67% が2026年公開
OpenSSH 自身の判断	AI による報告の多くを「影響なし」とした

→ 何を脆弱性と数えるかで, ベンダと採番者の判断が割れている
→ 今日の「過剰検知」は「ベンダ情報との食い違い」と読んでほしい

LLM の出力は, 作ったら固定する

機械可読な形式ならそのまま使う
HTMLしかない・値が欠けているところだけ LLM を使う

固定するもの	使い方	適用先
データ	欠けた値を一度だけ作る	Fortinet 旧アドバイザリ:456件中421件が検知条件を得た
コード	取得・抽出のコードを作らせ, 毎日はコードだけ動かす	Apple, Microsoft
変換結果	原文が変わったときだけ変換し, 結果をGitに残す	OpenSSH —— 原文にない値の混入は, まだ機械的に止められない

供給源は, 付与率ではなく検知精度で, 製品ごとに選ぶ

想定①	VulnCheckで補完できる → **製品による**（救いにも害にもなる）
想定②	2023年以前ならNVDで十分 → **成り立たない** （付与率100%の時代から誤りはあった）
理由	**付いている ≠ 合っている** NVD付与率 99.6% でも, 記述の一致は 63.1%
測り方	同じスキャン結果に, データベースだけを差し替える
限界	ベンダ情報も正解とは限らない（何を脆弱性と数えるかで割れる）
手段	機械可読ならそのまま取り込む 足りないところだけ LLM を使い, 出力は作ったら固定する
今後	ベンダ情報を取るべき製品を, より広い範囲で見分ける

Appendix

VulnCheckを足すとき, VulsはNVDを優先している

目的: NVDが条件を付けていない製品だけ, VulnCheckで補う

規則: NVDが当該CVEにその製品のCPEを定義していれば, VulnCheckの同じ製品の検知を捨てる

macOS 10.13.3	1,501件を抑制し, 取りこぼしは5件 → よく働く
Cisco IOS XE 16.12.1	抑制112件中31件(27.7%)はベンダ情報も検知 → 正しい検知を捨てている
Windows 11 23H2	833件が抑制されずに残り, ベンダ情報との一致は0件

→ この規則も, NVD の条件が「付いている」かだけ見て,「合っている」かは見ない

→ 直すべきは規則ではなく,「Windows 全般」のような機能しない条件の見分け方

VulnCheckの独自CPEは, 日単位で入れ替わる

例	CVE-2015-4000 の suse:suse_linux_enterprise_server
入れ替わり	更新された334回のスナップショットのうち, **305回**で有無が入れ替わる

→ 検知が日ごとに出たり消えたりして, 本当の変化かデータの揺れかを区別できない

VulnCheckでも, 国内ベンダ製品はほぼ埋まらない

採番元別の NVD 付与率（2024年以降公開, Rejected を除く）



VulnCheckの強みは，網羅性ではなく速さ

起点	NVD	VulnCheck
CVEの公開 （全体の標本）	中位数 7日・未付与 42.6%	中位数 1日・未付与 22.6%
Ciscoのアドバイザリ公開	中位数 16日・未付与 48.3%	中位数 1日・未付与 10.4%

測り方: スナップショットを1日2回取得してGitで履歴管理し，CPE適用条件が初めて現れた日を求めた